

Cyber-Bedrohungen & Resilienzstrategien

Vorlesungsskript · Sitzung 4 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ markierten Kästen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

1. Einleitung und Zielsetzung der Sitzung

Die bisherigen Sitzungen behandelten Resilienz zunächst aus einer definitorischen und messorientierten Perspektive (Sitzung 1 und 2) und anschließend aus architekturtechnischer Sicht (Sitzung 3). In dieser vierten Sitzung wird derselbe Gegenstand — Resilienz — nun **bedrohungsgetrieben** betrachtet: Resilienz wird nicht abstrakt verstanden, sondern stets in Bezug auf konkrete Störereignisse und Angriffsszenarien.

Resilienz ist im Kern nie allgemeingültig, sondern **immer relational**: Ein System ist nur insofern resilient, als es gegen *etwas Konkretes* widerstands- oder wiederherstellungsfähig ist. In diesem Sinne ist Resilienz nicht nur ein Architekturprinzip, sondern auch eine **Antwort auf Bedrohungsklassen**. Diese Perspektive findet sich u. a. explizit in NIST SP 800-160 Vol. 2 (*Cyber Resilience Engineering*), das Resilienzfähigkeiten funktional an Bedrohungsszenarien koppelt, sowie in den sektoralen Leitlinien von ENISA und dem BCM-Ansatz des BSI-Standards 200-4.

Die Sitzung verfolgt drei Ziele:

1. Bedrohungen als Resilienztreiber identifizieren

- Ransomware, DDoS, Cloud-Ausfälle, Identity-Ausfälle, Human Failure, Supply-Chain-Angriffe

2. Zuordnung von Bedrohungen zu Resilienzprinzipien

- Mapping von Threats auf Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität

3. Ableitung konkreter technischer Resilienzmaßnahmen

- nicht im Sinne von Prävention, sondern zur Aufrechterhaltung bzw. Wiederherstellung der Funktionsfähigkeit

Die Sitzung etabliert damit den notwendigen Brückenschlag zwischen *Threat Intelligence* und *Resilience Engineering*. Sie beantwortet nicht die Frage, wie man Angriffe verhindert, sondern wie Systeme so gestaltet werden, dass sie **trotz realer Ereignisse weiter funktionsfähig bleiben oder kontrolliert zurückkehren können**.

2. Bedrohungsklassen als Auslöser für Resilienz Anforderungen

Resilienzmaßnahmen entstehen nicht im Vakuum, sondern werden durch konkrete Bedrohungsszenarien begründet. In der Praxis zeigt sich, dass wenige wiederkehrende Bedrohungsklassen den überwiegenden Anteil realer Resilienz Anforderungen determinieren. Diese Bedrohungen unterscheiden sich weniger in ihrer technischen Ursache als in ihrem **Wirkmechanismus auf die Funktionsfähigkeit** eines Systems.

2.1 Ransomware und destruktive Malware

Diese Klasse von Bedrohungen zielt nicht primär auf Datenexfiltration, sondern auf **Denial-of-Service durch Sabotage** (Verschlüsselung, Löschung, Korruption). Relevanz für Resilienz: Recovery-Fähigkeit tritt als *primäre Verteidigungslinie* auf.

2.2 DDoS- und Lastangriffe

Diese Angriffe zerstören keine Ressourcen, sondern **verbrauchen sie schneller als sie bereitgestellt werden können**. Sie testen nicht Integrität, sondern Kapazität und Adaptivität.

Relevanz für Resilienz: Systeme müssen unter Degradation weiter liefern können.

2.3 Infrastruktur- und Cloud-Provider-Störungen

Regionale Cloud-Ausfälle, Stromausfälle, Netzwerk-Partitionen oder physische RZ-Störungen führen zu **extern erzwungenen Betriebsunterbrechungen**. Relevanz für Resilienz: Redundanz und Fallback-Konzepte entscheiden über Weiterbetrieb.

2.4 Identity- und Authentifizierungs-Ausfälle

Systeme können intakt sein und dennoch unbenutzbar werden, wenn zentrale Identity-Provider (AD/IdP) ausfallen oder kompromittiert werden. Relevanz für Resilienz: Identity fungiert als häufig unterschätzter Single Point of Failure.

2.5 Human Failure und Fehlkonfiguration

Ein signifikanter Anteil realer Großausfälle ist nicht Angriff, sondern **Fehlerfortpflanzung über Automatisierung** (IaC, CI/CD, Fehldeployments). Relevanz für Resilienz: Wiederherstellbarkeit und Rollbackfähigkeit überkompensieren menschliche Fehlbarkeit.

2.6 Supply-Chain-Angriffe

Kompromittierung über Drittanbieter bzw. Abhängigkeiten führt zu *importierter Fragilität* (SolarWinds, Kaseya).

Relevanz für Resilienz: Diversität und vertrauensunabhängige Recovery-Pfade sind Schlüsselfaktoren.

Zwischenfazit: Diese Bedrohungsklassen unterscheiden sich in ihrer Ursache, aber sie **konvergieren in ihren Effekten**: Verlust von Verfügbarkeit, Nutzbarkeit, Steuerbarkeit oder Integrität. Genau diese Effekte bestimmen, **welches Resilienzprinzip** angewendet werden muss.

3. Mapping: Von Bedrohung zu Resilienzprinzip (Threat → Capability)

Resilienzmaßnahmen entfalten nur dann Wirkung, wenn sie an den **Wirkmechanismus** einer Bedrohung anschließen. Die Bedrohung definiert also nicht nur *dass* Resilienz benötigt wird, sondern *welche Art* von Resilienzfähigkeit erforderlich ist.

Das folgende Mapping bildet diese Beziehung zwischen Ursache (Threat), Wirkung (systemischer Effekt) und Gegenprinzip (Resilience Capability) ab.

Bedrohung	Wirkung auf das System	Relevantes Resilienzprinzip
Ransomware	vollständiger Funktionsverlust	Wiederherstellbarkeit (Recovery)
DDoS / Lastangriffe	Degradation statt Zerstörung	Adaptivität
Cloud-/RZ-Ausfall	infrastrukturelle Nichtverfügbarkeit	Redundanz
Identity-Ausfall	Nutzungsunfähigkeit trotz intakter Systeme	Diversität & Recovery
Human Failure	ungewollte Fehlpropagation	Rollback / Wiederherstellbarkeit
Supply-Chain-Angriff	externer Fehler importiert	Diversität & Isolation

Die Mapping-Logik zeigt:

- Die Bedrohung entscheidet **nicht über das Tool**, sondern über das **Prinzip**, das anzuwenden ist.
- Verschiedene Bedrohungen können dasselbe Prinzip adressieren (z. B. Ransomware & Human Failure → Recovery).
- Dasselbe Prinzip kann gegen sehr verschiedene Bedrohungen wirken (z. B. Diversität gegen Identity-Ausfall & Supply-Chain).

Dieses Denken entspricht dem von NIST SP 800-160 Vol. 2 beschriebenen Paradigma „Capability-based Resilience“:

Nicht die Bedrohung wird kontrolliert — sondern die Fähigkeit, ihren Effekt zu absorbieren.

4. Ausgewählte Bedrohungen im Detail & zugehörige Resilienzstrategien

Die im Mapping skizzierten Zusammenhänge werden im Folgenden exemplarisch vertieft. Ziel ist nicht die vollständige technische Abdeckung, sondern das Verständnis des Wirkmechanismus und der **resilienzrelevanten Gegenmaßnahmen** im Gegensatz zu reiner Prävention.

4.1 Ransomware / destruktive Angriffe

Wirkmechanismus: Funktionsverlust durch Verschlüsselung oder Löschung produktiver Systeme (inkl. Replikate/Backups bei lateralem Spread).

Resilienzstrategien:

- Immutable / offline Backups (nicht durch denselben Blast-Radius beeinflussbar)
- Gold-Images & Clean-Room-Recovery
- Geübte Recovery-Tests (nicht nur Planexistenz)

Prinzipbezug: Wiederherstellbarkeit > Prävention (vgl. ISO/IEC 27031; BSI-200-4: testing over documentation)

4.2 DDoS / Lastangriffe

Wirkmechanismus: Nicht Zerstörung, sondern **kapazitive Erstickung** — Dienst technisch intakt, aber nicht konsumierbar.

Resilienzstrategien:

- Anycast-CDN / Scrubbing / Rate-Limiting

- Auto-Scaling statt statischer Kapazität
- Graceful Degradation (z. B. reduzierte API-Funktionalität)

Prinzipbezug: Adaptivität als Resilienzform (vgl. ENISA DDoS Best Practices)

4.3 Cloud-/RZ-Ausfall

Wirkmechanismus: Umgebung fällt exogen aus, Funktion bricht nicht wegen des Systems, sondern wegen des Standortes/Providers.

Resilienzstrategien:

- Multi-AZ / Multi-Region / Multi-Cloud
- Lokale Fallback-Services für Minimalbetrieb
- Trennung von Steuer- und Ausführungsdomäne

Prinzipbezug: Redundanz + Entkopplung (vgl. NIST SP 800-160 Vol.2 „Diversity of Location“)

4.4 Identity-Ausfall

Wirkmechanismus: Systeme intakt, aber **nicht benutzbar**, da Authentisierung/Token-Ausgabe zentral blockiert.

Resilienzstrategien:

- Break-Glass-Accounts außerhalb des Identity-Stacks
- Zweiter unabhängiger IdP / Offline-Auth-Pfad
- Minimal-Access-Mechanismen ohne Cloud-Abhängigkeit

Prinzipbezug: Diversität + Recovery (vgl. Zero Trust Architecture — Reduktion globaler Kopplungspunkte)

4.5 Human Failure / Fehlkonfiguration

Wirkmechanismus: Fehler multipliziert sich über Automatisierung (CI/CD/IaC), aus lokalem Fehler wird systemischer.

Resilienzstrategien:

- Staging / Canary Deployment / Rollback-Fähigkeit
- Separation of Duties / Vier-Augen-Prinzip
- Post-Mortem-Kultur statt Schuldpersonensuche

Prinzipbezug: Wiederherstellbarkeit + Governance (vgl. BSI-200-4 Reifegradstufen „gelernt vs. dokumentiert“)

4.6 Supply-Chain-Angriffe

Wirkmechanismus:

Externe Kompromittierung wird „mitimportiert“ in die eigene Kontrollkette (SolarWinds-Typus).

Resilienzstrategien:

- Diversität in kritischen Dependencies (nicht Monokultur)
- Zero-Trust for Dependencies (keine implizite Vertrauensweitergabe)
- Recovery ohne Abhängigkeit vom kompromittierten Supplier-State

Prinzipbezug: Diversität + Isolation (vgl. ENISA Supply-Chain Risk Guidance)

5. Normative Verankerung: Wie Frameworks Bedrohung → Resilienz koppeln

Resilienzmaßnahmen sind nicht frei interpretierbar, sondern in etablierten Normen als **fähigkeitsbezogene Reaktionen auf Bedrohungsszenarien** beschrieben. Damit ist Resilienz nicht nur ein Architekturthema, sondern ein **prüf- und nachweisfähiges Steuerungsprinzip**.

5.1 NIST SP 800-160 Vol. 2 – Capability-based Resilience

NIST formuliert Resilienz als Menge von Fähigkeiten (*capabilities*), die **explizit an Störereignisse gebunden** sind.

Die Kernkategorien — *Resist, Detect, Respond, Recover, Adapt* — wirken nicht unabhängig, sondern entlang beobachtbarer Bedrohungsfolgen. Resilienz wird damit **nicht an der Ursache, sondern am Effekt** ausgerichtet.

Hinweis zur Aktualität

NIST SP 800-160 Vol. 2 Rev. 1 (2021) definiert Cyber-Resilienz über die Ziele *Anticipate, Withstand, Recover, Adapt* [1]. Die hier verwendeten Begriffe (*resist, re-constitute* u. a.) stammen aus älteren Fassungen bzw. der Terminologie der Lehrveranstaltung. Siehe [Quellen, Hinweis 1](#).

5.2 ISO/IEC 27031 – ICT Readiness for Business Continuity

ISO/IEC 27031 versteht Resilienz als Nachweisfähigkeit über:

- definierte Ziele (RTO/RPO),
- getestete Recovery-Fähigkeit,
- wiederkehrende Validierung (Exercises & Lessons Learned).

Der Standard fordert damit Resilienz **gegen konkrete Ausfallszenarien** — nicht nur vorbereitende Dokumentation.

5.3 BSI-Standard 200-4 – Reifegrad statt Checkliste

BSI-200-4 bewertet nicht, ob Maßnahmen existieren, sondern **wie wirksam sie im Ereignisfall** betrieben werden können.

Der Reifegrad bemisst sich **an der geübten Fähigkeit**, nicht an der formalen Existenz.

Hinweis zur Aktualität

Die finale Fassung des BSI-Standards 200-4 (Mai 2023) unterscheidet drei Stufen: Reaktiv-BCMS, Aufbau-BCMS und Standard-BCMS [2]. Die hier gezeigte fünfstufige Skala ist als allgemeines Reifegradmodell zu verstehen, nicht als Stufenmodell des Standards. Siehe [Quellen, Hinweis 3](#).

5.4 ENISA – Sektorale Resilienz mit Threat-Fokus

ENISA-Guidelines adressieren Resilienz immer **sektorspezifisch** (z. B. Energie, Gesundheit, Finanzmarkt), da Bedrohungsmodelle sektoral divergieren. Resilienz wird dort nicht generisch, sondern **bedrohungsnah** formuliert.

Quintessenz: Normen bewerten Resilienz nicht als abstrakte Eigenschaft, sondern als **funktionale Antwortfähigkeit auf definierte Störungstypen**.

Damit sind Threat-to-Resilience-Mappings nicht optional, sondern methodisch gefordert.

6. Übung: Threat-to-Resilience-Mapping (Gruppenarbeit)

Die Übung dient der Überführung des Threat-Driven-Denkens in ein strukturiertes Analyse- und Argumentationsschema. Sie ist nicht als kreative Brainstorming-Aufgabe konzipiert, sondern als **präzise Zuordnungsaufgabe** entlang der in dieser Sitzung vermittelten Logik.

Aufgabenstellung Wählen Sie in Gruppenarbeit **eine der folgenden Bedrohungen**:

- Ransomware
- DDoS / Lastangriff
- Cloud-/Region-Ausfall
- Identity-Ausfall (IdP)
- Human Failure / Fehlkonfiguration
- Supply-Chain-Angriff

Beantworten Sie strukturiert:

1. Wirkmechanismus

Wie genau führt die Bedrohung zur Funktionsbeeinträchtigung? (1–2 Sätze)

2. Zuordnung zu Resilienzprinciples

Welches der vier Prinzipien (Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität) ist vorrangig relevant – und warum?

3. Konkrete Resilienzmaßnahmen

Nennen Sie je Prinzip mindestens eine technisch realistische Maßnahme.

4. Kurzfazit

Ist das System nach Umsetzung der Maßnahmen *resilient*, *bedingt resilient* oder weiterhin *fragil*? Begründen Sie in einem Satz.

Form des Ergebnisses

- 1 Slide oder 1 Blatt mit maximal 6 Bulletpoints
- Präsentationszeit pro Gruppe: 2–3 Minuten
- Bewertungskriterium: **Schärfe der Zuordnung, nicht Menge der Maßnahmen**

Weiter mit dem abschließenden Kapitel.

7. Zusammenfassung & Prüfungsrelevanz

Die Sitzung hat gezeigt, dass Resilienz nicht von der Bedrohung entkoppelt verstanden werden kann. Sie ist nicht „allgemein vorhanden“ oder „absolut“, sondern immer eine **Antwort auf einen konkreten Störmechanismus**. Bedrohungen unterscheiden sich weniger durch ihre Ursache als durch deren Auswirkung auf Funktionsfähigkeit, Steuerbarkeit und Wiederanlauf.

Kernpunkte dieser Sitzung

- Resilienz ist **relational** — sie existiert nur im Bezug zu einem Störungsszenario.
- Bedrohungsklassen (Ransomware, DDoS, Cloud-Failure, Identity, Human Error, Supply Chain) erzeugen **unterschiedliche Anforderungen**.

- Die vier Resilienzprinzipien (Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität) wirken als **strukturierter Antwortraum**.
- Normen (NIST SP 800-160 Vol.2, ISO/IEC 27031, BSI-200-4, ENISA) verankern dieses Mapping methodisch, nicht optional.
- Resilienzbewertung ohne Threat-Bezug ist **konzeptionell unvollständig**.

Prüfungsrelevante Leitfragen

- Warum ist Resilienz ohne Threat-Bezug methodisch unzureichend?
- Welche Bedrohung adressiert primär das Prinzip Wiederherstellbarkeit und warum?
- Wie unterscheidet sich das Wirkmodell eines DDoS von dem einer Ransomware — und wie spiegelt sich das im Resilienzdesign?
- Wie begründet BSI-200-4, warum Tests wichtiger sind als Dokumente?
- Erklären Sie an einem Beispiel, warum Identity ein versteckter SPOF ist.

Bibliografie

- [1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: [10.6028/NIST.SP.800-160v2r1](https://doi.org/10.6028/NIST.SP.800-160v2r1).
- [2] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.